

GRC102 — Information Security Governance

Week 1 Practical Laboratory

Information Security Governance in Action — GlobalHealth Connect (GHC) Executive Governance Simulation

Student Name: Diana Wanjiru

Registration Number: C11/26/CGRCE/17188

Submitted to: ICDFA E-Campus

Date: 11 September 2026

Declared AI assistance: Claude (Anthropic) was used for drafting support, structuring and language editing. All analysis, judgements and decisions were reviewed and are owned by the student.

Executive Summary

This report responds to the Week 1 Practical Laboratory brief for GlobalHealth Connect (GHC), a mid-sized health-technology organisation whose ad-hoc security approach is no longer sustainable following rapid growth, two acquisitions and a contained data-leakage near-miss. Acting as Director of Information Security Governance, this report designs a governance blueprint (Task 1), drafts a formal Information Security Charter (Task 2), translates six months of security data into a Board-level report (Task 3), establishes a Security Steering Committee to resolve cross-functional conflict (Task 4), and assesses GHC's governance maturity with a 12–18 month roadmap to reach Level 3 (Defined) across all domains (Task 5).

Task 1: Governance Blueprint

1.1 Current-State Governance Gap Assessment

#	Weakness	Why It Matters
1	No accountable security leadership role. John Smith (IT Manager) performs security activities alongside infrastructure duties, with no dedicated, senior, accountable owner.	Security decisions are made informally by someone without governance authority or a cross-functional mandate — this is the single largest gap exposed by the near-miss.
2	No cross-functional decision or escalation body exists.	Disputes (e.g., between technical and business priorities) have no structured forum for resolution, risking inconsistent or unilateral decisions.
3	Security and compliance operate in parallel rather than together. Mark Johnson (Compliance) manages regulatory obligations largely separately from John Smith's technical activities.	Regulatory risk and technical risk are assessed in isolation, increasing the chance that compliance gaps or technical vulnerabilities are missed.
4	Security is not embedded in the HR lifecycle. Robert Green owns onboarding/offboarding with no described security requirements (e.g., access provisioning and timely deprovisioning).	Weak joiner-mover-leaver controls are a common root cause of unauthorised access and insider risk, particularly after acquisitions bring in new staff.
5	Fragmented, inherited policy base following two acquisitions, with no unifying governance layer.	Inconsistent policies across the combined organisation create uneven control coverage and make audit and regulatory demonstration difficult.
6	No formal Board reporting or metrics translation existed before the near-miss forced attention.	The Board could not exercise informed oversight or hold management accountable for security outcomes.

1.2 Proposed Governance Organisational Chart

The structure below creates a single accountable governance owner reporting to the CEO with direct Board access, and a cross-functional committee that brings technology, compliance, HR and finance perspectives into security decisions:

- Board of Directors (David Miller — Board liaison for security oversight)
- Chief Executive Officer — Sarah Chen
 - Director of Information Security Governance (new role) — reports to CEO; direct quarterly reporting line to the Board
 - Security Steering Committee — chaired by the Director of Information Security Governance
 - CTO — Elena Rodriguez (technology & product risk)
 - IT Manager — John Smith (technical control implementation)
 - Compliance Officer — Mark Johnson (regulatory obligations)
 - HR Manager — Robert Green (workforce lifecycle controls)

- CFO — Marcus Thorne (investment, enterprise risk)
- Business/technical contributors as needed — e.g., Jane Doe (Development), Emily White (Finance data)

1.3 RACI Matrix — Governance Activities

Governance Activity	Board	CEO	Director ISG	CTO	IT Mgr	Compliance	HR Mgr
Policy approval	I	A	R	C	C	C	I
Risk review (register & assessment)	I	I	A/R	C	R	C	I
Incident response planning	I	I	A	C	R	C	C
Security awareness training	I	I	A	I	C	C	R
Access management (onboarding/offboarding)	I	I	A	I	R	C	R
Third-party / acquisition risk assessment	I	I	A	C	C	R	I

R = Responsible, A = Accountable, C = Consulted, I = Informed.

1.4 How the Structure Supports Good Governance

- Accountability: a single Director of Information Security Governance owns outcomes, replacing informal, distributed ownership with a named accountable role for each activity in the RACI matrix.
- Transparency: defined reporting lines from the Director to the CEO and Board, plus Steering Committee minutes, ensure decisions and risk information are visible rather than informal and undocumented.
- Business alignment: the Steering Committee's cross-functional membership (technology, compliance, HR, finance) ensures security decisions weigh business impact, not only technical risk.
- Risk management: routing risk review and incident-response planning through a defined accountable owner, supported by consulted specialists, closes the gap exposed by the ad-hoc handling of the recent near-miss.

Task 2: Information Security Charter

2.1 GHC Information Security Charter

Purpose

The GHC Information Security Programme exists to protect the confidentiality, integrity and availability of patient and organisational information, enabling GHC to pursue its growth, innovation and market-expansion goals while maintaining customer trust and regulatory standing.

Scope

This Charter covers all information assets, systems and data (including patient health information and financial data) owned, operated or processed by GHC or on GHC's behalf; all employees, contractors and temporary staff; and all third parties, vendors and newly acquired entities integrated into GHC's operations.

Authority

This Charter is issued under the authority of the Chief Executive Officer and ratified by the Board of Directors. It grants the Director of Information Security Governance the authority to set security policy and standards, direct risk-treatment decisions within delegated thresholds, mandate compliance with approved policy, and escalate unresolved or high-severity risks directly to the CEO and Board.

Roles and Responsibilities

High-level accountabilities are established through the governance structure and RACI matrix defined in Task 1: the Board provides oversight and approves risk appetite; the CEO holds ultimate management accountability; the Director of Information Security Governance owns programme delivery and reporting; the Security Steering Committee provides cross-functional decision-making; and business, technology, compliance and HR functions execute controls within their domains.

Key Principles

- Risk-based: security effort and investment are prioritised according to assessed risk to patients, data and the business.
- Business-aligned: security decisions support GHC's strategic goals — market expansion, operational efficiency, customer trust, innovation and regulatory excellence.
- Proportionate: controls are appropriate to the sensitivity of the asset and the risk presented, avoiding unnecessary friction to innovation and productivity.
- Continuously improving: the programme is measured, reviewed and matured over time rather than treated as a one-off project.

Reporting Structure

The Director of Information Security Governance reports operationally to the CEO and provides direct quarterly briefings to the Board. The Security Steering Committee meets monthly and reports its decisions and key risks to the Director, who consolidates them into Board reporting. Critical incidents are escalated immediately outside the standard reporting cycle.

Review and Approval

This Charter is approved by the CEO and Board of Directors. It is reviewed annually, or earlier upon material change such as a new acquisition, significant regulatory change, or a major incident. The Director of Information Security Governance owns version control and change history.

2.2 Justification Memo to Marcus Thorne, CFO

Marcus — this Charter gives GHC a single accountable owner and a documented decision-making structure for security investment, replacing the ad-hoc spending and reactive incident costs the organisation has carried to date. By tying security principles directly to our 2026 strategic goals, it ensures that investment is prioritised where it protects revenue and reduces cost: safeguarding patient trust protects the customer base underpinning our 25% growth target, proportionate controls support the 99.99% uptime and efficiency goals rather than obstructing them, and demonstrable governance reduces the cost and disruption of regulatory audits as we expand into two new regional markets.

From a risk and ROI perspective, the Charter converts security spending from reactive, incident-driven cost into planned, risk-prioritised investment reviewed by the Steering Committee and reported to the Board. This should reduce the financial exposure of future incidents like the recent near-miss, support due-diligence and integration costs for future acquisitions, and give you a clear, auditable basis for evaluating security budget requests going forward.

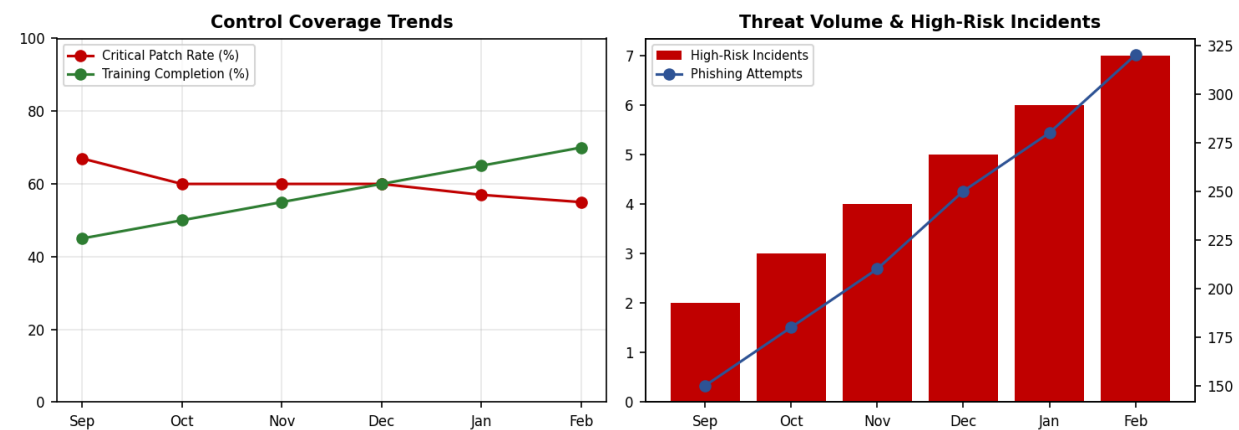
Task 3: Board Reporting and Security Metrics

3.1 Board Executive Summary

Overall Security Posture: AMBER-RED.

Justification: high-risk security incidents have risen from 2 to 7 over six months (a 250% increase), while the critical-vulnerability patch rate has declined from 67% to 55% over the same period, indicating that remediation capacity is not keeping pace with the volume of critical vulnerabilities identified. This combination — rising high-severity outcomes alongside a shrinking share of critical vulnerabilities closed — represents a growing, unmanaged exposure window. The one clearly positive trend is security-awareness training completion, which has improved steadily from 45% to 70%, showing that culture-building efforts are taking hold even as technical risk indicators worsen. The posture is assessed as Amber-Red rather than Red because no major data breach has yet occurred and a clear, actionable remediation path exists (Section 3.3).

3.2 Selected Metrics, Trends and Commentary



Metric	Current Status (Feb)	6-Month Trend	Business Commentary
High-risk security incidents	7 incidents	Up from 2 to 7 (+250%)	The clearest indicator of realised business risk; a sustained upward trend directly threatens the zero-major-breach goal and warrants immediate Board attention.
Critical vulnerability patch rate	55%	Down from 67% to 55%	Fewer than six in ten known critical vulnerabilities are being closed each month even as the total identified is growing — this is the leading driver of rising risk exposure.
Security awareness training completion	70%	Up from 45% to 70%	Strong, consistent improvement; a positive leading indicator that

Metric	Current Status (Feb)	6-Month Trend	Business Commentary
			should be sustained and eventually linked to measured behaviour change (e.g., phishing susceptibility).
Phishing attempts (volume)	320 in February	Up from 150 to 320 (+113%)	Reflects a growing external threat environment rather than an internal control failure; provides context for interpreting incident and training trends.
Malware detections	50 in February	Up from 25 to 50 (+100%)	Rising detections alongside rising incidents suggest endpoint and detection controls are under increasing pressure and should be reviewed for adequacy.

3.3 Priority Risks and Recommendations

Priority Risks

- Widening remediation gap: the critical-vulnerability patch rate has declined for four consecutive months while the volume of critical vulnerabilities identified has more than doubled, creating a growing window of exposure to known, exploitable weaknesses.
- Rising realised risk outpacing awareness gains: high-risk incidents have more than tripled even as training completion improves, indicating that technical and process controls — not just user behaviour — are a significant and growing gap.

Recommendations

- Establish an SLA-driven patch and vulnerability-management process with dedicated remediation capacity, tracked monthly by the Security Steering Committee, with an explicit target to restore the patch rate above 90% within two quarters.
- Accelerate deployment of technical controls — particularly multi-factor authentication and endpoint detection and response — to address the rising incident trend directly, complementing (not replacing) the training investment already delivering results.

3.4 Rationale for Metric Selection

These five metrics were selected because each is directly decision-useful for the Board rather than purely technical: they combine a leading indicator (training completion), a control-effectiveness indicator (patch rate), an outcome indicator (high-risk incidents), and environmental context indicators (phishing and malware volume) so the Board can distinguish rising external threat pressure from internal control performance. Each metric ties directly to GHC's strategic goals — protecting customer trust, supporting regulatory excellence, and enabling informed investment decisions — and each is expressed in trend form so the Board can see direction of travel, not just a single point-in-time value.

Task 4: Security Steering Committee

4.1 Security Steering Committee — Terms of Reference

Element	Detail
Purpose	To provide a structured, cross-functional forum for security-related decision-making, prioritisation, conflict resolution and oversight, ensuring decisions balance risk, business needs and technical practicality.
Scope	Policy review and approval recommendations; resolution of cross-functional disagreements (e.g., the password-policy dispute); risk-acceptance decisions within delegated authority; oversight of security initiative and roadmap progress.
Membership	Director of Information Security Governance (Chair); CTO (Elena Rodriguez); IT Manager (John Smith); Compliance Officer (Mark Johnson); HR Manager (Robert Green); CFO or finance representative (Marcus Thorne); business/technical representatives co-opted as needed (e.g., Jane Doe, Development).
Responsibilities	Review and recommend policy for approval; resolve cross-functional conflicts using documented, risk-based reasoning; monitor the security KPI/KRI dashboard; escalate unresolved or high-severity issues to the CEO and Board.
Meeting cadence	Monthly standing meetings, with ad hoc sessions convened for urgent cross-functional issues or significant incidents.
Decision authority	Decisions are sought by consensus. Where consensus cannot be reached, the Chair issues a risk-based recommendation; unresolved or high-impact disputes are escalated to the CEO for final decision. The Committee may approve policy and control changes within Board-delegated risk thresholds.
Reporting	Meeting minutes and decisions are reported to the CEO monthly and summarised for the Board quarterly as part of standard security reporting.

4.2 Sample Agenda — First SSC Meeting

- 1. Welcome, introductions and ratification of the SSC Terms of Reference.
- 2. Review of the recent data-leakage near-miss and initial lessons learned.
- 3. Password policy conflict — CTO's balanced proposal (multi-factor authentication plus password-manager-supported passphrases) versus the IT Manager's proposed 16-character, 30-day rotation policy; discussion of risk, usability and productivity trade-offs; decision on a recommended approach.
- 4. Review of the proposed governance blueprint and RACI matrix (Task 1) for endorsement.
- 5. Overview of current security metrics and Board reporting approach (Task 3).
- 6. Action items, ownership and date of next meeting.

4.3 Briefing Note to the CEO

Sarah — the Security Steering Committee gives GHC a standing, cross-functional forum to resolve disagreements like the current password-policy dispute through structured, risk-based discussion rather

than informal escalation between individuals. At its first meeting, the Committee will weigh the IT Manager's control-focused proposal against the CTO's usability-focused alternative and is expected to recommend a balanced approach — aligned with current password-security guidance — that favours multi-factor authentication and password-manager support over rigid complexity and frequent forced rotation, reducing user friction without weakening protection.

More broadly, the Committee ensures that future cross-functional issues are resolved consistently, with decisions documented and reported through the Director of Information Security Governance rather than resolved ad hoc. This keeps technology, compliance, HR and business priorities aligned with GHC's overall strategy, and gives you and the Board visibility into how and why security decisions are made.

Task 5: Governance Maturity Assessment

5.1 Current-State Maturity Assessment

Governance Domain	Current Level	Evidence / Rationale
Policy & Documentation	2 – Initial	Policies exist but are inconsistent, inherited from acquisitions, and not consistently kept current — some documentation exists but lacks standardisation.
Roles & Responsibilities	1 – Ad Hoc	Security ownership and accountability are unclear, with activities performed informally rather than through defined, assigned roles.
Risk Management	1 – Ad Hoc	The organisation is reactive with no formal, proactive risk-assessment process; the recent near-miss was handled without a documented process.
Metrics & Reporting	2 – Initial	Technical metrics exist and are collected, but they are not consistently translated into business-relevant reporting for leadership or the Board.
Training & Awareness	2 – Initial	Annual training is mandatory and does occur, but engagement is low, indicating the process exists without being effectively embedded.
Compliance	2 – Initial	Compliance preparation is audit-driven rather than continuously monitored, meaning activity exists but is reactive and periodic rather than standardised.

5.2 12–18 Month Maturity Roadmap

Initiative	Objective	Key Activities	Measurable Outcome
1. Governance Foundation (Months 1–4)	Establish accountable governance roles and an approved mandate.	Appoint Director of Information Security Governance; ratify the Charter (Task 2); stand up the Security Steering Committee; document and communicate the RACI matrix (Task 1).	100% of governance roles assigned and documented; Charter formally approved by the Board.
2. Policy Harmonisation (Months 3–8)	Replace inconsistent, inherited policies with a single, standardised policy set.	Inventory all policies inherited from acquisitions; gap-assess against a recognised baseline (e.g., ISO/IEC 27001 or NIST CSF); consolidate, approve and publish.	A single approved policy library covering all required domains, version-controlled and reviewed on a defined cycle.
3. Proactive Risk Management (Months 4–10)	Move from reactive to documented, proactive risk management.	Implement a formal risk register; conduct quarterly risk assessments; embed a security risk assessment step into future acquisition due diligence.	Risk register operational with assigned owners; four completed quarterly risk assessments within the period.

Initiative	Objective	Key Activities	Measurable Outcome
4. Metrics & Board Reporting (Months 6–12)	Convert technical data into standardised, business-relevant Board reporting.	Define a core KPI/KRI set (building on Task 3); build a recurring reporting dashboard; establish a quarterly Board reporting cadence with RAG assessment.	Quarterly Board reports delivered on schedule for four consecutive quarters, each with a consistent five-metric RAG assessment.
5. Training & Culture Uplift (Months 8–14)	Increase the effectiveness and engagement of security awareness activity.	Introduce role-based training content; launch a phishing-simulation programme; track engagement and link outcomes to team-level reporting.	Training completion at or above 85%, with a measurable reduction in phishing-simulation click-through rate.

5.3 Executive Summary to the Board

GHC's information security governance currently sits at Maturity Level 1–2 (Ad Hoc to Initial) across all six assessed domains: roles and risk management are largely informal, while policy, metrics, training and compliance activities exist but are inconsistent and not yet standardised. This is not proportionate to GHC's scale, its handling of sensitive patient data, its regulatory obligations, or its acquisition-driven growth, and it is a direct contributor to the conditions that allowed the recent near-miss to occur.

The proposed 12–18 month roadmap sequences five priority initiatives — governance foundation, policy harmonisation, proactive risk management, Board-level metrics reporting, and training uplift — to bring every domain to Level 3 (Defined), meaning documented, standardised and clearly accountable processes. Achieving this is strategically important: it reduces the residual risk behind incidents like the near-miss, strengthens GHC's position with regulators and healthcare customers, and provides the credible governance foundation needed to support continued growth, further acquisitions and expansion into new regional markets.

Note on Sources and Terminology

Governance terminology (governance, policy, standard, procedure, RACI, steering committee, maturity model) follows the working definitions provided in the laboratory brief (Appendix B). Password-security guidance referenced in Task 4 reflects current published guidance favouring multi-factor authentication and passphrase length over frequent forced rotation and high complexity requirements (e.g., NIST Special Publication 800-63B, Digital Identity Guidelines: Authentication and Lifecycle Management). All organisational facts, roles and data used in this report are drawn from the laboratory brief; no external organisational evidence has been fabricated.